

Manual 13 - Implementación Controlada SOX ITGC / ICFR

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: bd95c57ec7c4f55f6c2c8720afa1ad9df4c16679 | Idioma: es-419 | se mantienen los límites de autoridad SOX/SEC/PCAOB.

Límite jurídico y de auditoría: Este manual ofrece guía práctica para controles tecnológicos de ICFR. No proporciona asesoría jurídica específica, no determina materialidad, condición de emisor, exenciones, clasificación de deficiencias, alcance del auditor ni garantiza cumplimiento SOX. Las fuentes vigentes y el juicio humano competente siguen siendo controlantes.

Rutas de implementación

Manual 13 — Rutas de implementación SOX ITGC / ICFR

Borrador localizado asistido por máquina. La fuente inglesa controlada rige el significado hasta completar revisión semántica humana competente.

Ruta Esencial

Defina alcance ICFR tecnológico, sistemas y procesos significativos, responsables, ITGC básicos de acceso/cambios/operaciones, evidencia, pruebas de gerencia y remediación.

Manual 03 memory graphic 1

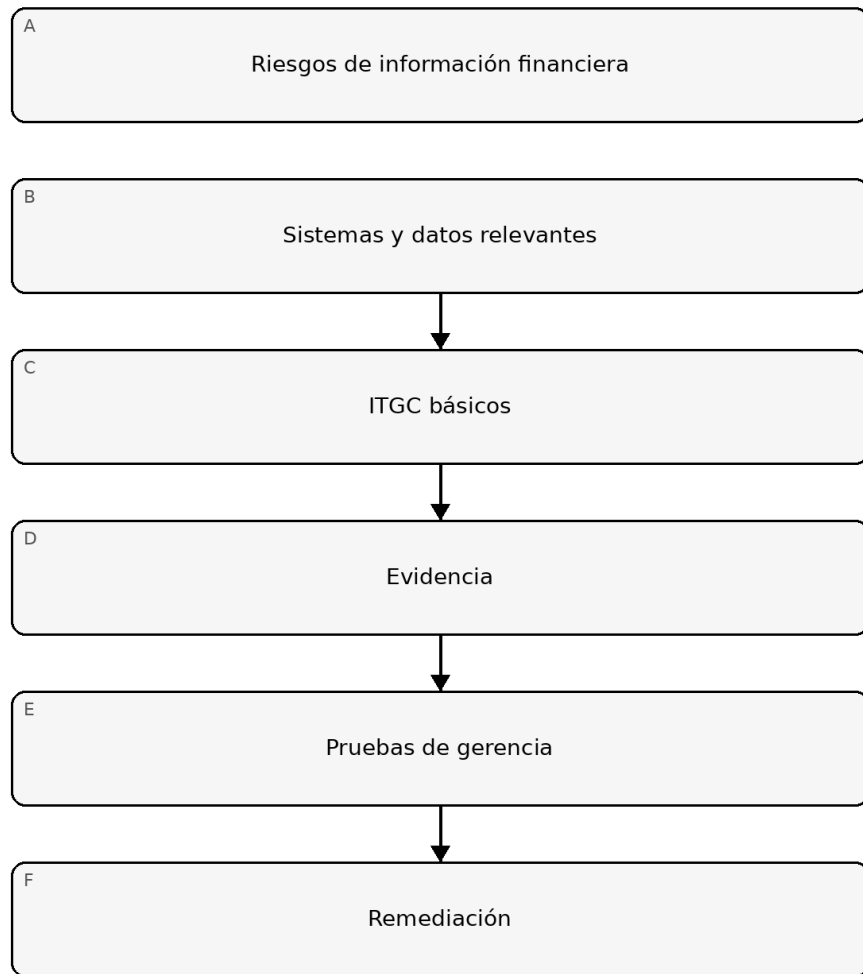


Figure 1. Implementation memory graphic

Explicación accesible: Comience con riesgos financieros, identifique tecnología de soporte, opere ITGC, retenga evidencia, pruebe controles y remedie fallas.

Ruta Estructurada

Agregue vínculo con aseveraciones, controles de completitud de población, procedimientos estandarizados, validación IPE, gobierno de organizaciones de servicio y soporte formal a certificaciones.

Manual 03 memory graphic 2

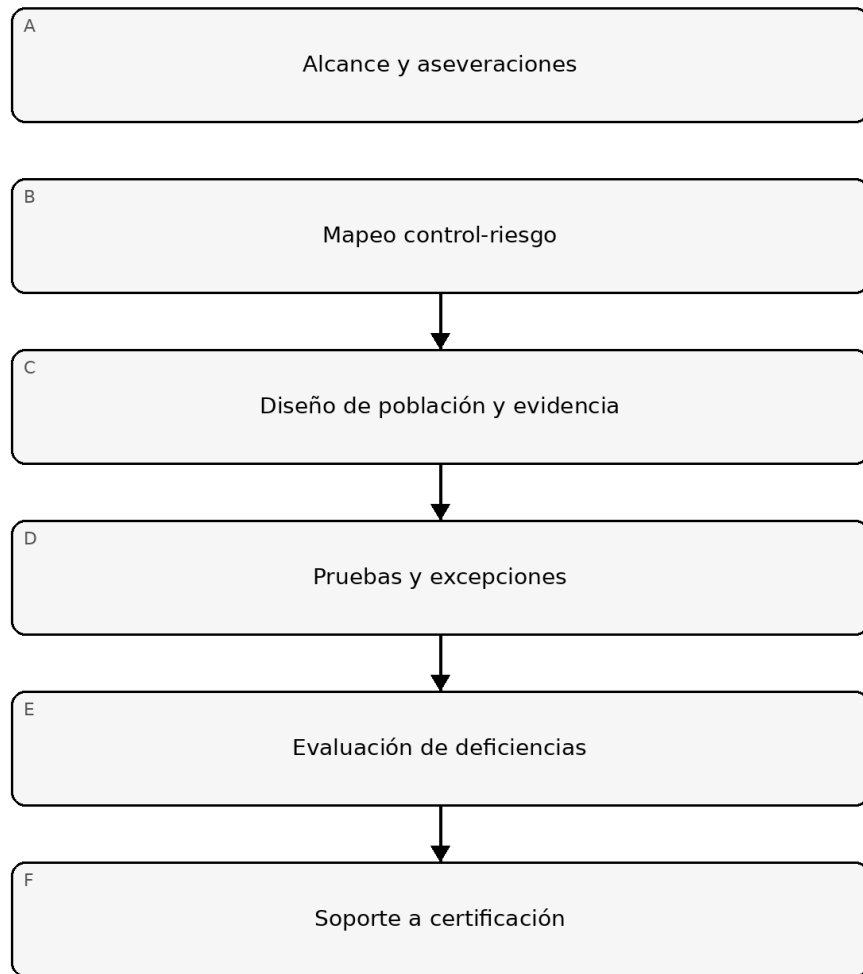


Figure 2. Implementation memory graphic

Explicación accesible: La ruta estructurada conecta alcance y aseveraciones con controles, valida poblaciones/evidencia, administra excepciones y alimenta la certificación.

Ruta Mejorada

Incorpore monitoreo continuo, procedencia automatizada de evidencia, analítica de configuración/identidad, detección de cambios, integración cloud/SaaS y gobierno de IA/automatización financieramente relevante.

Manual 03 memory graphic 3

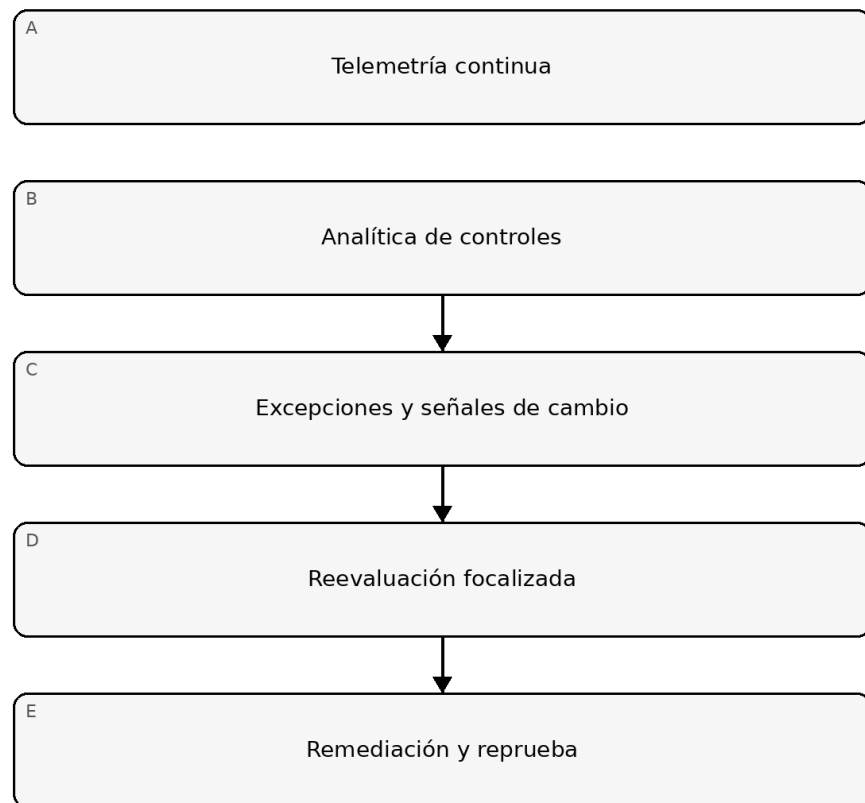


Figure 3. Implementation memory graphic

Explicación accesible: El modelo mejorado usa señales continuas para detectar excepciones, disparar reevaluación, remediar y volver a probar.

Manual controlado de 32 capítulos

Capítulo 1 — Propósito y límite operativo

Este manual convierte obligaciones tecnológicas relacionadas con SOX/ICFR en un modelo práctico de gobierno, control y evidencia. Distingue ley y reglas de la SEC, requisitos de auditoría del PCAOB, orientación regulatoria y marcos de implementación opcionales. No sustituye asesoría jurídica ni juicio profesional sobre materialidad, aplicabilidad o alcance de auditoría.

Capítulo 2 — Contexto de las Secciones 302 y 404

Las certificaciones ejecutivas de la Sección 302 y la evaluación de ICFR de la Sección 404 requieren responsabilidades relacionadas pero distintas. Debe existir un mapa de responsabilidades que conecte certificación, controles, sistemas, reportes y escalamiento.

Capítulo 3 — Gerencia frente a auditor externo

La gerencia diseña, opera, evalúa y documenta ICFR. El auditor externo realiza una evaluación independiente cuando corresponde. Las pruebas de gerencia deben mantenerse separadas de los procedimientos del auditor.

Capítulo 4 — Alcance y aplicabilidad

Defina entidad, cuentas y revelaciones relevantes, procesos significativos, aplicaciones financieras, interfaces, infraestructura, proveedores, reportes y hojas de cálculo. Documente por qué cada componente está dentro o fuera del alcance.

Capítulo 5 — Riesgo de información financiera y aseveraciones

Vincule riesgos de procesos con aseveraciones, cuentas/revelaciones, controles automatizados, reportes, interfaces y dependencias de TI. Cada ITGC debe explicar cómo su falla podría afectar un objetivo de información financiera.

Capítulo 6 — Gobierno y responsabilidad

Asigne responsables ejecutivos, dueños de procesos y controles, dueños de sistemas, custodios de evidencia, evaluadores, revisores y responsables de remediación. Defina escalamiento para fallas, excepciones repetidas y remediaciones vencidas.

Capítulo 7 — Controles tecnológicos a nivel de entidad

Los controles a nivel de entidad incluyen gobierno de acceso, cambios, operaciones, seguridad, riesgos, monitoreo y supervisión de sistemas financieros. Una política general no prueba por sí sola eficacia operativa.

Capítulo 8 — Dominios ITGC y relevancia para ICFR

Organice ITGC en acceso a programas y datos, cambios, desarrollo/adquisición y operaciones, complementados por interfaces, IPE/reportes y dependencias modernas cuando corresponda. Evite ampliar SOX a controles de ciberseguridad sin vínculo financiero.

Capítulo 9 — Gobierno de acceso lógico

Defina altas, cambios, bajas, acceso privilegiado, cuentas de servicio, acceso de emergencia y revisiones periódicas para sistemas financieramente relevantes. La evidencia debe mostrar solicitud, aprobación, implementación, retiro oportuno, revisión, excepciones y remediación.

Capítulo 10 — Segregación de funciones y acceso privilegiado

Identifique combinaciones incompatibles que permitan transacciones, cambios, asientos, datos maestros o encubrimiento de errores. Donde la segregación técnica no sea viable, documente y pruebe controles compensatorios.

Capítulo 11 — Gestión de cambios

Exija solicitud autorizada, evaluación de impacto, pruebas, aprobación, migración controlada, restricción de acceso a producción y evidencia posterior. Distinga cambios rutinarios, estándar, de emergencia, configuración, código, infraestructura como código y cambios SaaS.

Capítulo 12 — Desarrollo, adquisición e implementación

Para nuevos sistemas o implementaciones importantes, documente requisitos, diseño de controles, conversión de datos, validación de interfaces, UAT, acceso, segregación, corte, reversión y monitoreo posterior.

Capítulo 13 — Operaciones informáticas

Controle trabajos programados, lotes, interfaces, respaldos, recuperación, monitoreo, fallas, reprocesos, incidentes y cambios operativos. La evidencia debe demostrar detección y resolución de excepciones.

Capítulo 14 — Interfaces y transferencias de datos

Mantenga inventario de interfaces financieramente significativas y controles de integridad, exactitud, autorización, conciliación, manejo de errores, rechazos y duplicados.

Capítulo 15 — Reportes e información producida por la entidad (IPE)

Valide fuente de datos, parámetros, lógica, acceso, historial de cambios y completitud/exactitud de reportes, consultas, extracciones, tableros y cálculos usados en controles o información financiera.

Capítulo 16 — Hojas de cálculo y computación de usuario final

Clasifique hojas de cálculo y herramientas EUC por riesgo. Aplique propiedad, acceso, control de versiones/cambios, protección o revisión de fórmulas, validación de entradas, conciliación, respaldo y revisión independiente.

Capítulo 17 — Eficacia del diseño

Evalúe si cada control, ejecutado como fue diseñado, preveniría o detectaría oportunamente el riesgo de información financiera. Documente objetivo, disparador, población, ejecutor, precisión, evidencia, dependencias y escalamiento.

Capítulo 18 — Eficacia operativa

Determine si el control operó durante el periodo, por personal apropiado, con evidencia consistente y seguimiento oportuno. Defina población y periodo antes de seleccionar muestras.

Capítulo 19 — Diseño y retención de evidencia

Especifique evidencia esperada, sistema de origen, responsable, ubicación de retención, periodo, vínculo con la población y atributos de revisión. Prefiera evidencia generada naturalmente por el control.

Capítulo 20 — Completitud de población y preparación para muestreo

Documente cómo se generan las poblaciones, por qué son completas, filtros, duplicados, exclusiones y registros faltantes. El tamaño de muestra requiere juicio profesional y no se prescribe universalmente.

Capítulo 21 — Organizaciones de servicio y terceros

Mapee servicios subcontratados que afectan ICFR, controles complementarios de la entidad usuaria, subservice organizations, informes de control, contratos, incidentes, cambios y brechas. Un informe SOC no prueba automáticamente cobertura total.

Capítulo 22 — Nube y SaaS

Documente responsabilidades compartidas para servicios financieramente relevantes: configuración, acceso privilegiado, federación de identidad, cambios, registros, respaldo, interfaces y evidencia disponible.

Capítulo 23 — IA y automatización en procesos financieros

Cuando IA, RPA o automatización influya en cálculos, clasificaciones, conciliaciones, aprobaciones, reportes o evidencia, documente propósito, entradas, salidas, supervisión humana, cambios, acceso, validación, monitoreo y contingencia.

Capítulo 24 — Identificación y escalamiento de deficiencias

Registre fallas de control, brechas de diseño, fallas de evidencia, excepciones repetidas y dependencias afectadas. Separe el hallazgo factual de la clasificación jurídica o de auditoría como deficiencia significativa o debilidad material.

Capítulo 25 — Planificación de remediación

Para cada hallazgo identifique causa raíz, objetivo afectado, sistemas/procesos, dueño del riesgo, acción correctiva, fecha objetivo, control interino, evidencia y criterios de reprobación.

Capítulo 26 — Reprobación y cierre

La reprobación debe confirmar diseño y operación de la remediación. Conserve hallazgo original, evidencia de corrección, evidencia de reprobación, conclusión del revisor y aprobación de cierre.

Capítulo 27 — Soporte a certificaciones de gerencia

Integre estado de controles, cambios significativos, deficiencias, remediaciones, entradas del proceso de revelación y asuntos abiertos. Las representaciones tecnológicas deben ser trazables a evidencia del periodo.

Capítulo 28 — Interacción con auditor externo

Mantenga un proceso controlado de entrega de evidencia con seguimiento de solicitudes, responsables, fechas, versiones y escalamiento. No altere evidencia subyacente solo para ajustarla a una solicitud.

Capítulo 29 — Monitoreo continuo y reevaluación

Use métricas, recertificación de accesos, datos de incidentes, trabajos fallidos, excepciones y antigüedad de remediaciones para detectar deterioro. El monitoreo no reemplaza operación ni pruebas independientes.

Capítulo 30 — Rutas Esencial, Estructurada y Mejorada

Esencial: alcance defendible, ITGC básicos, responsables, evidencia y gestión de deficiencias. Estructurada: vínculo riesgo-aseveración, poblaciones, pruebas estandarizadas, terceros y remediación integrada. Mejorada: monitoreo continuo, procedencia automatizada de evidencia, analítica de configuración y reevaluación disparada por cambios.

Capítulo 31 — Fallas comunes y escenarios

Fallas comunes incluyen sobrealcance de ciberseguridad, capturas sin evidencia poblacional, confianza automática en informes SOC, validación débil de IPE, accesos privilegiados no resueltos, cambios de emergencia sin revisión y cierre de remediaciones sin reprobación.

Capítulo 32 — Lista final de operación y publicación

Verifique estado actual de fuentes SOX/SEC/PCAOB, alcance, responsables, trazabilidad, evidencia, fidelidad de localización, accesibilidad, procedencia e historial de cambios. Para publicación, vincule hashes exactos, QA, revisiones, manifiesto, seguridad de workflow y reconciliación de registro/catálogo.

Apéndice de evidencia y pruebas para practicantes

Apéndice de evidencia y pruebas para practicantes — Manual 13

A. Hoja de trabajo control-riesgo

Para cada control tecnológico financieramente relevante registre riesgo de información financiera, proceso/cuenta/revelación, aseveración u objetivo afectado, sistema o dato dependiente, dueño del control, ejecutor, frecuencia, fuente de evidencia, ubicación de retención, dependencias, ruta de excepción y disparador de reevaluación. Un revisor debe poder entender por qué el control está en alcance ICFR y cómo una falla podría afectar la información financiera.

B. Patrón de evidencia de acceso

Para accesos de usuario conserve solicitud, aprobación, rol o privilegio otorgado, fecha de implementación, administrador, registro del sistema, revisión periódica y remediación. Para acceso privilegiado incluya justificación, límites, monitoreo y recertificación. Para bajas demuestre la población fuente y oportunidad de retiro; capturas aisladas no prueban completitud.

C. Patrón de gestión de cambios

Para cambios financieramente relevantes conserve solicitud aprobada, evaluación de impacto, descripción/requisitos, pruebas, segregación, aprobación de migración, registro de despliegue y validación posterior. Los cambios de emergencia requieren base documentada y revisión retrospectiva. En SaaS y low-code, cambios de configuración, flujos, fórmulas, permisos e integraciones pueden ser tan significativos como cambios de código.

D. Patrón de operaciones informáticas

Para procesos programados identifique población esperada, monitoreo, criterios de falla, notificación, autoridad para reinicio/reproceso, conciliaciones y evidencia de resolución. El estado “exitoso” del scheduler puede ser insuficiente cuando la completitud financiera depende de conteos, totales de control o conciliaciones posteriores.

E. Interfaces y conciliaciones

Documento origen/destino, frecuencia, población, mecanismo de transferencia, controles automatizados, manejo de rechazos, duplicados, conciliación, umbrales y responsables. Cuando la conciliación es manual defina precisión del revisor y escalamiento; si es automática, documento configuración/código, entradas, manejo de errores y monitoreo.

F. IPE y reportes

Cuando un control depende de un reporte, consulta, extracción o tablero, documento nombre, sistema, dueño, parámetros, periodo, filtros, fuente de datos, lógica y acceso. Para consultas ad hoc conserve script/consulta exacta. Para hojas de cálculo registre fuentes, fórmulas/macros, versión, acceso, revisión y conciliación. Una captura del reporte no sustituye evidencia reproducible de población.

G. Organizaciones de servicio

Por cada proveedor que afecte ICFR documente servicio, procesos/sistemas, informe o evidencia revisada, periodo, controles complementarios de la entidad usuaria, subservice organizations, excepciones, periodo puente, incidentes y conclusión de gerencia. Recibir un informe SOC no significa confiar automáticamente en todos los controles relevantes.

H. Mínimos del papel de trabajo de pruebas

Incluya ID del control, objetivo, riesgo, descripción, dueño, frecuencia, fuente de población, periodo, método, fundamento de muestra cuando corresponda, elementos probados, evidencia, excepciones, conclusión, revisor, fecha y seguimiento. Separe diseño de eficacia operativa y asegure que otro revisor competente pueda reproducir la lógica de la conclusión.

I. Deficiencia y remediación

Registre condición factual, objetivo afectado, proceso/sistema, duración, población potencial, controles compensatorios, causa raíz, contención, acción correctiva, dueño, fecha, evidencia de cierre y plan de reprobación. Mantenga los hechos separados de la clasificación final como deficiencia significativa o debilidad material.

J. Reevaluación por cambios

Reevalúe alcance y diseño ante implementación relevante, migración ERP, adquisición, nube, cambios de identidad, outsourcing, rediseño financiero, nueva interfaz, incidente material, excepción recurrente o introducción de IA/automatización financieramente relevante. Registre evento, alcance afectado, riesgos, controles modificados, evidencia y pruebas requeridas.

K. Escenario — acceso privilegiado

Un administrador financiero conserva privilegios después de una ventana de emergencia. Identifique sistemas/capacidades afectadas, revise actividad, corrija el acceso, evalúe monitoreo, registre la excepción y determine si se requiere ampliar pruebas. La clasificación final requiere juicio competente.

L. Escenario — parámetro incorrecto de reporte

Una conciliación mensual usa un filtro de fecha incorrecto durante dos periodos. Reproduzca poblaciones correctas, evalúe errores potencialmente no detectados, identifique controles alternos, corrija procedimiento/configuración, repruebe y evalúe la deficiencia con criterios vigentes y hechos específicos.

M. Escenario — cambio de configuración SaaS

Un proveedor modifica un flujo financiero configurable. Determine impacto en aprobaciones, acceso, cálculos, interfaces o evidencia; obtenga información disponible, compare configuración, pruebe el flujo, actualice documentación y reevalúe dependencia del proveedor.

N. Escenario — proceso financiero asistido por IA

Una herramienta de IA propone clasificaciones contables. Controle uso aprobado, procedencia de entradas, revisión de salidas, cambios, acceso, fallback, monitoreo, excepciones y evidencia. Los puntajes de confianza del modelo no prueban exactitud financiera; defina cómo la revisión humana valida resultados y escala anomalías.

O. Lista de evidencia de publicación

El paquete final debe vincular identidad exacta de la fuente controlada, verificación de fuentes autoritativas, fuentes trilingües, DOCX/PDF, QA de páginas, revisión de accesibilidad/visual, hashes, manifiesto, seguridad de workflows, reconciliación de cambios y decisiones de revisión aplicables ligadas al candidato exacto. La autorización final permanente ya está establecida por separado.